PROJET SISE-OPSIE 2026

Ricco RAKOTOMALALA, David PIERROT

1. Contexte

Le projet 2026 aborde des problématiques classiques et surtout connues reposant généralement sur la fouille de données et la détection des intrusions. Cette année, nous intégrons une revue d'utilisation des règles d'un Firewall généralement nécessaire pour une satisfaction normative (ISO 27001 , ANSSI).

Nous prenons en compte également une migration de ces règles vers un autre Firewall de même technologie. En résumé une analyse de règles sera faite à partir du log de Firewall Iptables de type on cloud et une migration de ces dernières sera à réaliser sur un Firewall de type Iptables On-Premise. La partie fouille de données sera à réaliser par la suite.

ELK pour pourra être utilisé pour certains éléments de ce challenge, une librairie python nommée (Elasticsearch) permet une interrogation d'un index ELASTIC.

Pour rappel, il s'agit d'un travail en équipe, les élèves OPSIE doivent apporter leurs connaissances métiers au SISE.

Les données et fichiers de configuration sont disponibles via le lien suivant :

challenge-2026

2. Principe de fonctionnement

- Par groupes de 5 (ou 6) étudiants, mixtes 2 (ou 3) OPSIE et 2 (ou 3) SISE
- Analyser des données d'un équipement de sécurité (Firewall Iptables on cloud) et fournir des métriques propres au SI hébergé.
- Fournir une revue d'utilisation des règles (policyid) aux formats docx ou pdf via l'utilisation du package R knitr, Python ou ELK. Pour information, il est possible d'interroger Elasticsearch en R ou en Python.
- Réaliser un projet en R Shiny / Python alimenté au niveau des données par un nouvel élément de filtrage de type Firewall (Iptables). Les règles de sécurité créées via l'option « -j –LOG –log—prefix » d'Iptables permettront l'export des événements vers une solution de journalisation de type Syslog-Ng ou Ulog2. Le moddle regorge d'exemples (vu en TD)

- Par la suite vous devrez travailler directement dans une base de données ou via Elasticsearch et **ceci selon votre convenance mais avec une concertation OPSIE/SISE.**

Ricco RAKOTOMALALA, David PIERROT

3. Détail du projet

Le projet est constitué de plusieurs parties qui offrent une vision globale qui fournit un tableau de bord sur l'état du SI. Il prend en compte aussi bien l'analyse des traces que le traitement des événements via un outil spécifique, sans oublier la détermination d'un modèle voire d'une tendance et d'une prise de décision.

Ce projet se veut modulaire et adapté aussi bien aux contraintes horaires que sur la difficulté des techniques à mettre en œuvre pour obtenir un résultat probant. Le terme « Challenge » correspond bien à ce projet qui en temps normal pourrait demander plusieurs semaines de travail.

1.1 Analyses des données fournies de type IPTABLES

Il est souvent recommandé de réaliser une revue d'utilisation des règles de filtrage sur les équipements de type Firewall. Ce principe permet de réduire le nombre de règles et conséquemment le temps d'analyse et de satisfaction aux actions (Matching : Accepté / Rejeté).

Comme déjà précisé, ce projet se veut modulaire, vous avez la possibilité d'utiliser un des deux jeux de données présentés ci-dessous ayant un niveau de difficulté croissant (disponibles au format zip).

1. log_export.log.zip: 11 997 652 de lignes de log dans un format semi-structuré séparé par un « ; » .
2. log_brute.log.zip: 11 997 652 de lignes de log au format natif iptables (complété avec –log-prefix)
3. log_export.parquet.zip : 11 997 652 de lignes au format parquet avec les entêtes.

L'utilisation de log natif étant légèrement plus difficile à extraire, une bonification sera accordée.

Dans les deux cas, les mois allant novembre 2025 à février 2026 devront être extrait pour la réalisation des travaux d'analyse. L'information relative au numéro du Firewall (FW=6) devra être supprimer.

Il convient de fournir un rapport au format docx ou pdf via l'utilisation du package R Knitr ou autre selon votre convenance. Le résultat devra permettre de visualiser avec des chapitres distincts les informations suivantes :

- Classement des règles les plus utilisées.
- Fournir un histogramme représentant l'utilisation des différents protocoles présents. Tcp et Udp ne sont pas forcément nommés ainsi dans le fichier de log, une déduction devra être faite selon les ports utilisés, idem pour les protocoles sans nom ou N.A.
- Top dix des règles les plus utilisées avec le protocole Udp.
- Top cinq des règles les plus utilisées avec le protocole Tcp.
- Fournir un rapprochement des règles (rule id) par rapport aux ports de destination et les action. Cette analyse portera uniquement sur le protocole par défaut Tcp.
- Fournir des graphiques vus lors TD qui vous semblent adéquats à la sécurité des SI.

En cas d'utilisation d'ELK, un Dashboard devra être fourni en mode interactif.

La conversion et l'extraction des données peuvent se faire via des commandes comme awk, cut ou encore via un script (python, perl, c#, Rscript, etc…). Il est aussi possible d'utiliser Syslog-Ng pour extraire les données dans les champs souhaités. Ces cas d'usage ont déjà été traités durant les TD des exemples sont disponibles sur le Moodle.

Logstash pourra être très utile pour intégrer les données dans Elastcisearch (si utilisation d'ELK). Des exemples de fichiers sont également disponibles.

*Pour rappel, si l'importation de certaines lignes dans un environnement R ou Python pose des problèmes, la commande sed peut être utilisée (sed numéro_ligne**p, ou sed –i.bak «**numéro_ligne**d »).***

1.2 Migration et préparation des données

Le système utilisé devra proposer les services suivants :

- FTP TCP port 20 :21
- SSH TCP port 22
- Telnet TCP port 23
- HTTP TCP port 80 (prévoir 2 répertoires accessibles nommés ***Backup*** et **Restore** et un fichier index.html à la racine).
- MYSQL/MARIADB TCP 3306 (utilisation interne 127.0.0.1, pas d'accès depuis une adresse externe).

Les règles de filtrage seront axées sur l'action LOG (ACCEPT et DENY ne seront pas utilisés). Le fichier conf-iptable-rpb.txt devra être importé, il est possible que le nom de l'interface réseau soit différent selon la distribution utilisée, le cas échéant il conviendra que le nom de l'interface soit modifié dans ce fichier.

Les actions suivantes devront être réalisées :

1. Configuration d'Iptables
2. Ajout dans le fichier conf-iptable-rpb.txt, les cinq ports de destination Tcp les plus utilisés sur les log Iptables Cloud et non présents dans le configuration Iptables.
3. A l'aide de Netcat ou d'une configuration vhost apache, ces cinq ports devront être joignables.
4. Configurer le serveur Syslog-ng à l'aide des fichiers syslog-ng.conf et rsyslog.xml.
5. Seul un administrateur est autorisé en SSH (adresse IP à votre convenance), pour tout autre accès, une règle Iptables devra limiter le nombre de connexions à 30 par heures (`tcp --syn -m connlimit --connlimit-above 100 -m limit --limit 30/hour --limit-burst 1)`

Les TD réalisés sur *Iptables* et *Syslog-Ng* devraient pouvoir vous aider ainsi que la commande ***pdbtools***.

Les données transformées par le système de journalisation seront les suivantes :

- *Date : Année-mois-jour heures : minutes : secondes*
- *Adresse IP Source*
- *Adresse IP de destination*
- *Protocole (TCP/UDP)*
- *Port de destination utilisé*
- *Action : Permit ou Deny.*
- *Id de la règles firewall (999 étant la cleanup)*
- *Interface d'entrée*
- *Interface de sortie*

1.3 Architecture souhaitée ou conseillée (mais libre) :

Afin de faciliter la mise en place d'une architecture proche de la réalité, nous vous proposons la solution suivante :

Une distribution Kali linux ou Docker (ulog) hébergera les services cités dans le début (chapitre 1.2). Les règles de firewall seront positionnées sur cette même distribution (voir conf-iptables-rpb.txt). Un server rsyslog est installé par défaut et ce dernier transféra les log d'Iptables à un serveur distant syslog-ng. La configuration de Rsyslog est assez simple. Dans le répertoire /etc/rsyslog.d/, il suffit de créer une fichier challenge.conf (exemple dans dossier /Modèles Base et connecteurs/challenge.conf) et de saisir les lignes suivantes et selon les versions de rsyslog utilisées:

- :msg, contains, "RULE=" **@@adresse_ip_syslog_ng**:514 (ancienne configuration type de rsyslog)
- if $msg contains "RULE=" then action(type="omfwd" target="**adresse_ip_syslog_ng** "
  port="514" protocol="**udp**"
  action.resumeRetryCount="100"
  queue.type="linkedList" queue.size="10000"
)

  & stop

Pour information, Filebeat de la suite ELK peut être utilisé pour envoyer les log iptables à syslog-ng, ceci permet de se passer de rsyslog.

Il conviendra par la suite de redémarrer rsylog et de veiller à l'activation des règles Iptables. Les log Iptables doivent être envoyés à un serveur Syslog-Ng. La commande suivante doit également permettre de confirmer que les traces sont bien transférées :

- Tcpdump -vvttttnn -XX dst port 514

Si toutefois, vous souhaitez utiliser un iptables sous Docker, il conviendra d'utiliser ***Ulogd2*** pour transmettre les logs (voir TD **iptables -j NFLOG --nflog-group 1 --nflog-prefix " votre message : ")**

Pour rappel, Logstah peut émuler un serveur syslog (voir exemple dans partage du Challenge).

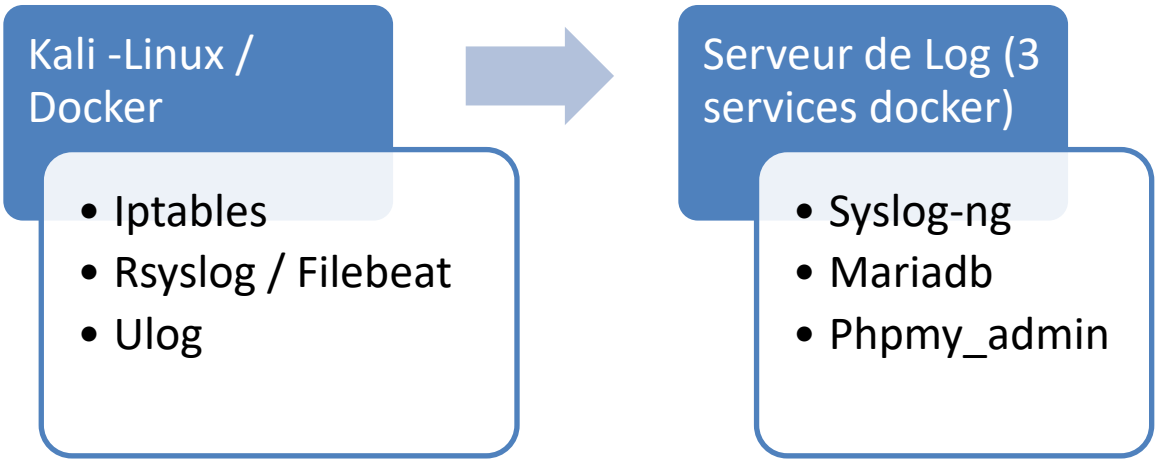


Figure 1 : Proposition architecture

1.3.1 Création de du server Syslog-ng

Le serveur recevra les données issues de rsyslog/filebeat et sera créé via Docker. Il sera composé des éléments suivants :

- Serveur Syslog-ng
- Serveur Mariadb
- Inteface Phpmyadmin

Des fichiers docker-compose ont été créés durant les TD et sont disponibles sous le Moodle.

1.4 Alimentation des données

Une fois les règles implémentées et la mise en condition opérationnelle de la solution de journalisation réalisée, vous devrez respecter les points suivants :

1. Réaliser des connexions « licites » vers les services proposés. La solution de journalisation doit s'alimenter automatiquement. Il est recommandé de procéder à 45 minutes **minimum** de test (la commande crontab peut s'avérer utile).
2. Effectuer un balayage des ports TCP allant de 1 à 65535.

Dans le même principe, vous réaliserez les actions illicites suivantes :

1. Balayage furtif avec 10 adresses différentes via une seule commande :

   10.0.0.1, 192.168.4.1, 172.156.2.26, 192.168.1.0, 10.10.1.101, 89.89.56.2, 28.12.15.20, 10.172.11.2, 194.25.56.2, 172.5.2.8.

2. Balayage furtif avec 10 adresses aléatoires
3. Balayage simple fragmenté et en ACK.
4. Balayage furtif via un zombi
5. Balayage furtif avec des adresses utilisées dans le plan d'adressage en cours d'utilisation (159.84/X/Y.).
6. Balayage avec un spoof-mac d'une adresse active sur le plan d'adressage en cours.

7. Attaque par *brute force* sur le service Ftp par l'utilisation d'un dictionnaire regroupant toute la possibilité de quatre caractères alphabétiques.
8. En utilisant l'outil DirBuster de l'OWASP ou Gobsuter, vous réaliserez une recherche des répertoires sur le service http. Pour votre information, DirBuster propose des dictionnaires rendant plus aisée la recherche de répertoires. Nous vous suggérons d'utiliser le plus réduit (Gobuster est connu pour sa célérité).
9. Attaque web via Nikto ou ZAP (https://www.zaproxy.org/download/).
10. Réaliser si possible une prise de renseignent avec Nuclei (https://www.it-connect.fr/tuto-nuclei-scanner-de-vulnerabilite-web/). Le fichier Dockerfile OPSIE est une bonne base de départ.
11. Balayage des 100 ports les plus utilisés avec un délai d'une seconde par ports interrogés.
12. Test de scripts de type nmap orientés « http » ,« ftp » et « ssh » .
13. Relaisser un DDOS via un syn flood avec metastploit (dos/tcp/synflood) et hping3 (--faster -udp IP --data 1500 --count 150000).

A l'issue de ces actions, le système de journalisation doit être assez fourni, il est temps de passer à l'analyse.

Ricco RAKOTOMALALA, David PIERROT

1.5 Fonction attendue - Web App Python

Remarque 1 (Obligatoire) : On vous demande de créer une Web App Python dynamique et interactive de visualisation et de traitement des données issues de la simulation. Vous pouvez la développer à l'aide des librairies de votre choix (Dash, Bokeh, Streamlit, ou autres…)

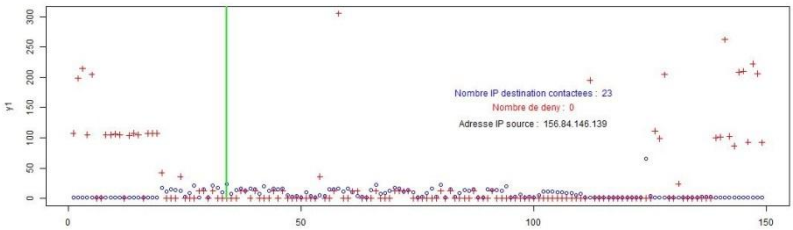
Remarque 2 (Obligatoire) : L'application doit être encapsulée dans une image docker que nous, David et moi, pouvons charger et lancer à partir de Docker Desktop.

Remarque 3 (Optionnel) : Vous pouvez également [en sus] déployer en ligne votre application. Il nous faut dans ce cas nous transmettre l'URL.

Cette partie repose sur 3 fonctionnalités de visualisation à réaliser

1. Analyse descriptive des flux rejetés et autorisés par protocoles (TCP, UDP). Une possibilité de filtrer par plages de ports selon la RFC 6056 (https://tools.ietf.org/html/rfc6056) serait appréciée. La représentation graphique ainsi que l'ergonomie sont laissées à votre bon goût et à votre créativité.
2. Parcours des données via l'utilisation de « renderDataTable ».
3. Visualisation interactive des données (IP source avec le nombre d'occurrences de destination contactées, incluant le nombre de flux rejetés et autorisés).
4. Fournir les statistiques relatives au TOP 5 des IP sources les plus émettrices, TOP 10 des ports inférieurs à 1024 avec un accès autorisé, lister les accès des adresses non inclues dans le plan d'adressage de l'Université.

Exemple de représentions possible pour le point 3



1.6 Partie analytique (Machine Learning - IA)

A partir des données issues des simulations, proposez des scénarios d'analyse que vous devez justifier : que souhaitez-vous mettre en évidence à partir de ces données, comment allez-vous organiser les données pour ce faire, quelles techniques utilisez-vous, quelle serait la lecture des résultats ?

Vous pouvez utiliser des techniques de visualisation factorielle, de classification automatique, ou encore des approches supervisées. Le plus important est de bien expliciter les objectifs de l'analyse et la plus-value que l'on pourra en retirer.

Mettez également à contribution les compétences nouvellement acquises autour des LLM (large language model) et de l'IA générative pour analyser différemment les données et produire des résultats lisibles et pertinents.

Vos outils analytiques doivent être intégrés dans l'application Web App. Autant que possible, ils doivent être interactifs de manière à ce que l'utilisateur puissent explorer (ex. filtres, options, etc.) les différents aspects des traitements que vous proposez.

Travaux à fournir, timing et présentations

Vous ne pourrez pas tout traiter. Choisissez des axes d'analyse et justifiez-les lors de la présentation.

Vous devez fournir un fichier archive zip incluant une présentation Powerpoint détaillant vos analyses, votre démarche et les principaux résultats obtenus, l'ensemble des fichiers R utilisés ainsi que le jeu de données créé via la solution de journalisation (Syslog-Ng : fichier plat ou une exportation au format csv de la base données), le code source de votre application dynamique Python avec des éventuelles indications sur les packages et configurations nécessaires pour la faire fonctionner correctement (fichier « requirements.txt » ou configuration YAML), l'accès à l'image docker que nous pourrons charger dans Docker Desktop, l'éventuelle URL de l'application si vous l'avez mise en ligne, l'éventuelle URL du GitHub dédié au projet.

Vous devrez fournir la commande History de la station utilisée pour les attaques mais également de votre firewall.

Mettez votre archive sur un drive et envoyez la référence le mardi 03 mars à 12h00 au plus tard aux adresses mail suivantes (ne mettez pas l'archive en fichier attaché) : ricco.rakotomalala@univ-lyon2.fr et david.pierrot1@univ-lyon2.fr. Indiquez dans le sujet l'identifiant de l'équipe (1, 2, etc.). Indiquez dans le message la liste des étudiants constituant le groupe.

A partir de 14h, nous passons aux présentations. L'ordre de passage des groupes sera défini par votre numéro d'équipe (Equipe 1 : 13h30, équipe 2 : 14h, …, pause, équipe 5 : 16h, …, équipe 8 : 17h30). Chaque groupe dispose de 25 mn avec :

- Une présentation de votre travail basé sur votre powerpoint (5 mn) ;
- Une partie démonstration de votre application Web App, mettez bien en évidence les principales fonctionnalités qui valorisent votre travail (5 mn) ;
- Les réponses aux questions que nous ne manquerons pas de poser (15 mn).

Bon courage.